Week 4 Meeting Notes - 20 October 2026

Team: Hanoi Group 5 (Team Lead: Le Tuan Huy) - COS40005 client meeting
Mentor: Robert Leyba (ISC2 Vietnam Chapter)
Score: 86/100 GREEN (approved by mentor, 2026-10-20)
Note: Scorecard week 4 (by planned date). The team described this as week 6 of their own semester plan. One member left near the end for another meeting.

Purpose of the Meeting

Review the end of Sprint 1 (research and tooling setup) and each member's research before the team starts building the prototype.

1. Project Management (Huy)

- Jira board and roadmap set up; Sprint 1 covers weeks 1-6 (research and tooling) and is almost finished.
- GitHub repository created; it will hold most of the codebase (templates only so far).
- Prototype build and testing starts next week (team's week 7).

2. Architecture and Routing (Do)

- Draft industry needs: speed, accuracy, human oversight, privacy and reliability; early load estimates.
- **FastAPI flow:** client sends a scenario, the API loads the evidence and a matching prompt template, routes the request to the model, validates the structured JSON, saves it to SQLite and returns the result.
- **Endpoints:** run a scenario, list scenarios, get saved results, record the analyst's decision to accept or override an AI recommendation, and a health check.
- **Prompt templates:** timeline and evidence summary mapped to MITRE ATT&CK techniques, with severity and recommended next steps.
- **Rules to reduce hallucination:** every claim must point to evidence, technique IDs are checked against ATT&CK, invalid JSON is retried once, and every call logs model ID, temperature, latency and timestamp to match the SQL schema.
- **Risk register** for LLM context limits, large log injection and API calls; about 600 AI calls estimated.
- **Next step:** measure the token size of the longest scenario using real public datasets and compare it to the chosen model's context limit (chunking or pre-filtering if needed). Privacy is a priority, so only public data (or data the owner approves) will be used.

- Do is compiling the team's research into one formal submission; not done yet.

3. Statistical Methodology and Telemetry Schema (Huyen)

- **Scrum-45, statistical methodology:** measure how well analysts investigate incidents with and without AI help, using precision, recall and F1 for accuracy and investigation time for efficiency. Approach aligned with the NIST AI Risk Management Framework.
- **Scrum-49, SQLite telemetry schema:** 10 tables tracking user actions, clicks, investigation time, AI suggestions and how analysts respond to them.
- 7 local tests written and passing (local machine only).
- Both tasks are awaiting final review by the team lead before backend integration.

4. AI Hallucination and Automation Bias (Scrum-44)

- LLMs can produce realistic but fabricated IOCs, such as made-up IP addresses, and rarely admit when they don't know.
- Automation bias: analysts tend to over-trust a system that is usually accurate and then miss threats the system misses.
- The risk grows in high-pressure SOC work with strict time constraints.

5. UI Requirements (Tin)

- Requirements document plus a design preview.
- The interface separates evidence, AI recommendations and the analyst's final findings.
- Three modes: human only, AI only, and human + AI combined.
- The analyst can accept, revise or reject AI advice without overwriting the original evidence.

6. Mentor Guidance

- The team is well prepared and ahead of expectations; the focus now moves from individual research to building a product.
- **How to connect the research (team question):** treat it as a web application. Pair the UI owner with the API/endpoint owner to get a working front end and back end, then wire in the AI layer and tools, then validate the whole stack. Hosting can be local or on a free online service.
- Put all the research into one combined document and use it (with AI help if useful) to scaffold the framework.
- **API key vs own model:** using an existing API (OpenAI, Gemini or similar) is fine given time. The mentor suggested doing both if possible: test with an API key now and try a small custom LLM in parallel. A machine-learning layer is an optional stretch goal.

- Mentor example: fine-tuning an open-weight Qwen model on malware data, then adding subagents for reverse engineering.

Action Items

- [ ] Consolidate individual research into one combined document
- [ ] Pair the UI owner with the API/endpoint owner and build a working front end + back end
- [ ] Obtain an API key (OpenAI, Gemini or equivalent) and test it against the prototype
- [ ] Measure token size of the longest scenario on a public dataset vs the model's context limit
- [ ] Team lead to review the statistical methodology and telemetry schema
- [ ] Optional: explore a small custom LLM in parallel if time allows